Ubuntu

```
mysticalmyth21@MysticalMyth21:~$ cd "/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied C
yber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files"
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ bandit -r
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.4
Run started:2026-10-13 13:14:09.481136+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: ./sample_code.py:2:0
1       import os
2       import subprocess
3       import yaml

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'P@ssw0rd123'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: ./sample_code.py:8:14
7       DB_USERNAME = "admin"
8       DB_PASSWORD = "P@ssw0rd123"  # Insecure: hardcoded password
9

--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: ./sample_code.py:23:4
22          # shell=True is insecure and should be flagged by Bandit
23          subprocess.run(command, shell=True)
24

--------------------------------------------------
>> Issue: [B506:yaml_load] Use of unsafe yaml load. Allows instantiation of arbitrary objects. Consider yaml.safe_load().
   Severity: Medium   Confidence: High
   CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b506_yaml_load.html
   Location: ./sample_code.py:33:15
32              # Insecure usage: yaml.safe_load should be used instead
33              data = yaml.load(f, Loader=yaml.Loader)
34          return data

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: ./sample_code.py:54:13
53          # Insecure: eval executes arbitrary code
54          result = eval(user_input)
55          print(f"Result: {result}")

--------------------------------------------------

Code scanned:
        Total lines of code: 54
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 2
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 4
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$
```

```
Run started:2026-10-13 13:16:15.396249+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications
associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#
b404-import-subprocess
   Location: ./sample_code.py:2:0
1     import os
2     import subprocess
3     import yaml

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password:
'P@ssw0rd123'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_st
ring.html
   Location: ./sample_code.py:8:14
7     DB_USERNAME = "admin"
8     DB_PASSWORD = "P@ssw0rd123"  # Insecure: hardcoded password
9

--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call
with shell=True identified, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with
_shell_equals_true.html
   Location: ./sample_code.py:23:4
22        # shell=True is insecure and should be flagged by Bandit
23        subprocess.run(command, shell=True)
24

--------------------------------------------------
>> Issue: [B506:yaml_load] Use of unsafe yaml load. Allows instantiation
of arbitrary objects. Consider yaml.safe_load().
   Severity: Medium   Confidence: High
   CWE: CWE-20 (https://cwe.mitre.org/data/definitions/20.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b506_yaml_load.html
   Location: ./sample_code.py:33:15
32            # Insecure usage: yaml.safe_load should be used instead
33            data = yaml.load(f, Loader=yaml.Loader)
34        return data

--------------------------------------------------
```

```
>> Issue: [B307:blacklist] Use of possibly insecure function - consider
using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b3
07-eval
   Location: ./sample_code.py:54:13
53        # Insecure: eval executes arbitrary code
54        result = eval(user_input)
55        print(f"Result: {result}")

--------------------------------------------------

Code scanned:
      Total lines of code: 54
      Total lines skipped (#nosec): 0
      Total potential issues skipped due to specifically being disabled
(e.g., #nosec BXXX): 0

Run metrics:
      Total issues (by severity):
            Undefined: 0
            Low: 2
            Medium: 2
            High: 1
      Total issues (by confidence):
            Undefined: 0
            Low: 0
            Medium: 1
            High: 4
Files skipped (0):
```

1. Static Analysis
Section: Static Analysis (SAST)
Observed: The tool scanned source code without executing it. It flagged issues by file and line number - e.g., insecure functions, hard-coded values, and missing input validation. Shows how vulnerabilities enter during coding.
Actions: Refactor flagged sections, enforce secure coding standards, add input validation/parameterized queries, and add SAST to CI/CD pipeline so it runs on every commit.
2. Dependency Scanning
Section: Dependency Scanning (SCA)
Observed: The scanner checked third-party libraries vs CVE databases. It found outdated dependencies with known high/medium vulnerabilities. Risk is from libraries you didn't write but depend on.
Actions: Update to patched versions, remove unused libs, enable Dependabot/automated updates, and keep an SBOM.
3. Secret Detection / YARA
Section: Secret Detection using YARA
Observed: YARA scanned for secret patterns (API keys, passwords, tokens). Output shows rule name + file path + whether any secrets were detected. If detected, it means credential leakage if pushed to GitHub.
Actions: Remove hard-coded secrets immediately, rotate/revoke exposed keys, move secrets to env variables or vault (HashiCorp Vault / AWS Secrets Manager), add pre-commit secret scanning (gitleaks).
Conclusion: This shows shifting left - finding code, dependency, and secret issues early in DevSecOps before production.

```
Ubuntu
mysticalmyth21@MysticalMyth21:~$ cd "/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files"
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ ls
requirements.txt  sample_code.py  secret_test.txt
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ nano myrules.yar
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ yara myrules.yar secret_test.txt
FindSecrets secret_test.txt
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ yara -s myrules.yar secret_tests
.txt
error scanning secret_tests.txt: could not open file
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$ yara -s myrules.yar secret_test.
txt
FindSecrets secret_test.txt
0x8a:$aws_secret: AWS_SECRET_ACCESS_KEY
0xe5:$password: password
0x175:$privatekey: BEGIN PRIVATE KEY
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and Applied Cyber Defense/M05T03 - Introduction to DevSecOps and Secure Deployment/Code Files$
```

Ubuntu

```
mysticalmyth21@MysticalMyth21:/mnt/u/Stellenbosch + HyperionDEV/Level 2 - Systems and App
Found 151 known vulnerabilities in 8 packages
```

Name	Version	ID	Fix Versions
flask	1.0	PYSEC-2023-62	2.2.5,2.3.2
flask	1.0	PYSEC-2023-62	2.2.5,2.3.2
flask	1.0	PYSEC-2026-2151	3.1.3
flask	1.0	PYSEC-2026-2151	3.1.3
requests	2.19.1	PYSEC-2018-28	2.20.0
requests	2.19.1	PYSEC-2018-28	2.20.0
requests	2.19.1	PYSEC-2023-74	2.31.0
requests	2.19.1	PYSEC-2023-74	2.31.0
requests	2.19.1	PYSEC-2026-1873	2.32.0
requests	2.19.1	PYSEC-2026-1872	2.32.4
requests	2.19.1	PYSEC-2026-2275	2.33.0
requests	2.19.1	PYSEC-2026-1873	2.32.0
requests	2.19.1	PYSEC-2026-1872	2.32.4
requests	2.19.1	PYSEC-2026-2275	2.33.0
django	2.2	PYSEC-2019-13	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2021-9	2.2.18,3.0.12,3.1.6
django	2.2	PYSEC-2019-14	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2019-16	1.11.27,2.2.9
django	2.2	PYSEC-2019-12	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2020-33	2.2.16,3.0.10,3.1.1
django	2.2	PYSEC-2021-8	2.2.22,3.1.10,3.2.2
django	2.2	PYSEC-2020-31	2.2.13,3.0.7
django	2.2	PYSEC-2022-2	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2020-36	1.11.29,2.2.11,3.0.4
django	2.2	PYSEC-2021-98	2.2.24,3.1.12,3.2.4
django	2.2	PYSEC-2019-10	1.11.22,2.1.10,2.2.3
django	2.2	PYSEC-2019-11	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2021-7	2.2.21,3.1.9,3.2.1
django	2.2	PYSEC-2021-6	2.2.20,3.0.14,3.1.8
django	2.2	PYSEC-2021-439	2.2.25,3.1.14,3.2.10
django	2.2	PYSEC-2021-99	2.2.24,3.1.12,3.2.4
django	2.2	PYSEC-2019-79	1.11.21,2.1.9,2.2.2
django	2.2	PYSEC-2020-35	1.11.28,2.2.10,3.0.3
django	2.2	PYSEC-2020-34	2.2.16,3.0.10,3.1.1
django	2.2	PYSEC-2019-15	2.1.15,2.2.8
django	2.2	PYSEC-2020-32	2.2.13,3.0.7
django	2.2	PYSEC-2022-3	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2022-1	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2022-20	2.2.27,3.2.12,4.0.2
django	2.2	PYSEC-2022-19	2.2.27,3.2.12,4.0.2
django	2.2	PYSEC-2022-190	2.2.28,3.2.13,4.0.4
django	2.2	PYSEC-2022-191	2.2.28,3.2.13,4.0.4
django	2.2	PYSEC-2022-19	2.2.27,3.2.12,4.0.2
django	2.2	PYSEC-2020-31	2.2.13,3.0.7
django	2.2	PYSEC-2021-98	2.2.24,3.1.12,3.2.4
django	2.2	PYSEC-2019-11	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2021-6	2.2.20,3.0.14,3.1.8
django	2.2	PYSEC-2019-16	1.11.27,2.2.9,3.0.1
django	2.2	PYSEC-2019-12	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2022-191	2.2.28,3.2.13,4.0.4
django	2.2	PYSEC-2022-20	2.2.27,3.2.12,4.0.2
django	2.2	PYSEC-2020-34	2.2.16,3.0.10,3.1.1
django	2.2	PYSEC-2020-36	1.11.29,2.2.11,3.0.4
django	2.2	PYSEC-2021-439	2.2.25,3.1.14,3.2.10
django	2.2	PYSEC-2019-79	1.11.21,2.1.9,2.2.2
django	2.2	PYSEC-2021-8	2.2.22,3.1.10,3.2.2
django	2.2	PYSEC-2021-9	2.2.18,3.0.12,3.1.6
django	2.2	PYSEC-2019-15	2.1.15,2.2.8
django	2.2	PYSEC-2021-7	2.2.21,3.1.9,3.2.1
django	2.2	PYSEC-2020-35	1.11.28,2.2.10,3.0.3
django	2.2	PYSEC-2022-3	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2019-10	1.11.22,2.1.10,2.2.3
django	2.2	PYSEC-2020-33	2.2.16,3.0.10,3.1.1
django	2.2	PYSEC-2022-2	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2019-14	1.11.23,2.1.11,2.2.4
django	2.2	PYSEC-2021-99	2.2.24,3.1.12,3.2.4
django	2.2	PYSEC-2020-32	2.2.13,3.0.7
django	2.2	PYSEC-2022-190	2.2.28,3.2.13,4.0.4
django	2.2	PYSEC-2022-1	2.2.26,3.2.11,4.0.1
django	2.2	PYSEC-2026-628	2.1.9,2.2.2
django	2.2	PYSEC-2022-245	3.2.15,4.0.7
django	2.2	PYSEC-2026-1297	4.2.16,5.0.9,5.1.1
django	2.2	PYSEC-2025-47	4.2.22,5.1.10,5.2.2
django	2.2	PYSEC-2025-105	4.2.24,5.1.12,5.2.6
django	2.2	PYSEC-2025-107	4.2.26,5.1.14,5.2.8

Ubuntu

django	2.2	PYSEC-2026-1297	4.2.16,5.0.9,5.1.1
django	2.2	PYSEC-2025-47	4.2.22,5.1.10,5.2.2
django	2.2	PYSEC-2025-105	4.2.24,5.1.12,5.2.6
django	2.2	PYSEC-2025-107	4.2.26,5.1.14,5.2.8
django	2.2	PYSEC-2025-108	4.2.26,5.1.14,5.2.8
django	2.2	PYSEC-2026-1297	4.2.16,5.0.9,5.1.1
django	2.2	PYSEC-2026-628	2.1.9,2.2.2
django	2.2	PYSEC-2026-3717	5.2.17,6.0.8,6.1.1
django	2.2	PYSEC-2026-198	5.2.15,6.0.6
django	2.2	PYSEC-2026-199	5.2.15,6.0.6
django	2.2	PYSEC-2026-201	5.2.15,6.0.6
django	2.2	PYSEC-2026-2090	5.2.16,6.0.7
django	2.2	PYSEC-2026-2091	5.2.16,6.0.7
django	2.2	PYSEC-2026-2092	5.2.16,6.0.7
django	2.2	PYSEC-2026-3717	5.2.17,6.0.8
django	2.2	PYSEC-2026-4035	5.2.17,6.0.8
pyyaml	5.3	PYSEC-2020-96	5.3.1
pyyaml	5.3	PYSEC-2021-142	5.4
pyyaml	5.3	PYSEC-2021-142	5.4
pyyaml	5.3	PYSEC-2020-96	5.3.1
cryptography	2.6.1	PYSEC-2021-62	3.2.1
cryptography	2.6.1	PYSEC-2021-62	3.2
cryptography	2.6.1	PYSEC-2023-11	39.0.1
cryptography	2.6.1	PYSEC-2026-800	39.0.1
cryptography	2.6.1	PYSEC-2026-1283	42.0.0
cryptography	2.6.1	PYSEC-2026-1285	42.0.2
cryptography	2.6.1	PYSEC-2026-2141	46.0.5
cryptography	2.6.1	PYSEC-2023-11	39.0.1
cryptography	2.6.1	PYSEC-2026-35	46.0.6
cryptography	2.6.1	PYSEC-2026-35	46.0.6
cryptography	2.6.1	PYSEC-2024-225	42.0.4
cryptography	2.6.1	PYSEC-2026-800	39.0.1
cryptography	2.6.1	PYSEC-2026-1283	42.0.0
cryptography	2.6.1	PYSEC-2026-1285	42.0.2
cryptography	2.6.1	PYSEC-2026-2141	46.0.5
cryptography	2.6.1	PYSEC-2026-3553	49.0.0
cryptography	2.6.1	PYSEC-2026-3554	49.0.0
cryptography	2.6.1	GHSA-5cpq-8wj7-hf2v	41.0.0
cryptography	2.6.1	GHSA-jm77-qphf-c4w8	41.0.3
cryptography	2.6.1	GHSA-v8gr-m533-ghj9	41.0.4
cryptography	2.6.1	GHSA-537c-gmf6-5ccf	48.0.1
jinja2	2.10	PYSEC-2021-66	2.11.3
jinja2	2.10	PYSEC-2019-217	2.10.1
jinja2	2.10	PYSEC-2019-217	2.10.1
jinja2	2.10	PYSEC-2021-66	2.11.3
jinja2	2.10	PYSEC-2026-1473	3.1.3
jinja2	2.10	PYSEC-2026-1474	3.1.4
jinja2	2.10	PYSEC-2026-1475	3.1.5
jinja2	2.10	PYSEC-2026-1471	3.1.6
jinja2	2.10	PYSEC-2026-1473	3.1.3
jinja2	2.10	PYSEC-2026-1471	3.1.6
jinja2	2.10	PYSEC-2026-1474	3.1.4
jinja2	2.10	PYSEC-2026-1475	3.1.5
idna	2.7	PYSEC-2024-60	3.7
idna	2.7	PYSEC-2024-60	3.7
idna	2.7	PYSEC-2026-215	3.15
idna	2.7	PYSEC-2026-215	3.15
urllib3	1.23	PYSEC-2019-133	1.24.2
urllib3	1.23	PYSEC-2019-132	1.24.3
urllib3	1.23	PYSEC-2020-148	1.25.9
urllib3	1.23	PYSEC-2019-133	1.24.2
urllib3	1.23	PYSEC-2020-148	1.25.9
urllib3	1.23	PYSEC-2019-132	1.24.3
urllib3	1.23	PYSEC-2026-1995	1.26.19,2.2.2
urllib3	1.23	PYSEC-2023-192	1.26.17,2.0.6
urllib3	1.23	PYSEC-2023-192	1.26.17,2.0.6
urllib3	1.23	PYSEC-2023-207	1.24.2
urllib3	1.23	PYSEC-2023-212	1.26.18,2.0.7
urllib3	1.23	PYSEC-2023-207	1.24.2
urllib3	1.23	PYSEC-2023-212	1.26.18,2.0.7
urllib3	1.23	PYSEC-2026-1999	2.5.0
urllib3	1.23	PYSEC-2026-1994	2.6.0
urllib3	1.23	PYSEC-2026-1996	2.6.3
urllib3	1.23	PYSEC-2026-141	2.7.0
urllib3	1.23	PYSEC-2026-141	2.7.0
urllib3	1.23	PYSEC-2026-1999	2.5.0
urllib3	1.23	PYSEC-2026-1995	1.26.19,2.2.2
urllib3	1.23	PYSEC-2026-1994	2.6.0
urllib3	1.23	PYSEC-2026-1996	2.6.3